

1. Explain CSRF (Cross-Site Request Forgery):

CSRF is an attack where a malicious website tricks a logged-in user's browser into making an unintended request to a trusted site where the user is authenticated. For example, if you're logged into your bank and visit a hacker's site, an embedded hidden form could submit `transfer?amount=1000&to=attacker` using your active session cookies. The bank's server sees the valid session and processes the request, thinking it's from you. To prevent CSRF, websites use anti-CSRF tokens (random unique values embedded in forms) that attackers can't guess, or require re-authentication for sensitive actions (e.g., PayPal asks for password again before sending money).

2. Authentication vs. Authorization:

Authentic ation	Authoriza tion
Verifies who you are – proves identity (e.g., login with username + password)	Determines what you can do – grants or denies access to resources/actions.
Always happens first – you must authenticate before authorization	Happens after authentication – checks permissions for the

on can occur.	verified user.
Example: Entering your Gmail email and password to log in.	Example: After login, Gmail allows you to <i>read</i> emails but <i>not</i> delete system logs or view admin settings.
Typically uses credentials (passwords, biometrics, OTPs, tokens).	Typically uses roles/permissions (e.g., <code>role = admin, can_edit = true</code>).

Analogy:
Showing
your ID
card at
the airport
security
desk.

Analogy:
Your
boarding
pass
decides
which
gate and
seat
you're
allowed to
access.